At ACME, these two needs developed simultaneously. Inside the company, microservices were growing rapidly. Teams had split the once-monolithic Customer Collaboration platform into smaller services, and HR and Finance departments had done the same. However, authorization logic was fragmented and inconsistent. The finance API should allow managers like Carol to access payroll data for their own team but not for the entire company. The HR API should share personal details with authorized employees but hide them from unrelated services. Enforcing such rules across dozens of APIs had become unmanageable.

At the same time, ACME's customers—Kate and Jack among them—needed to connect the other applications their employer, CustCo, relied on to the data inside ACME's systems, especially the Customer Collaboration platform. Kate wanted to feed her workspace data into CustCo's reporting service, while Jack needed to synchronize assignments with a task management app already used at CustCo. Allowing those applications to log in with Kate's or Jack's ACME credentials would have been insecure and all-or-nothing: each app would gain whatever access it had, with no way to limit or revoke it selectively.

To address these challenges, ACME adopted two complementary strategies. For internal service-to-service enforcement, they integrated Cedar with their API infrastructure to establish a centralized, fine-grained decision point. For external delegation, they adopted OAuth, allowing customers like Kate and Jack to delegate specific permissions to third-party applications without sharing passwords.

This chapter addresses those two challenges in turn. We'll begin with internal enforcement, where ACME realized that securing APIs is just as crucial—and often more complicated—than protecting the user-facing application. As their systems evolved toward microservices, each service boundary became an API surface that required protection. Later, we'll discuss external delegation, focusing on how customers like Kate and Jack use OAuth to grant secure access to other applications they use.